

This policy establishes the requirements for backing up and restoring Saudi EXIM Bank's information and IT assets. It ensures the confidentiality, integrity, and availability of data, supports regulatory compliance, and minimizes the impact of data loss or system disruption through defined processes, retention, and recovery testing.

Backup & Recovery Processes

Version	Approved By	Owner	Date Last Updated	Review Frequency	Next Review	Comments
1.0	Board of Directors	CISO	-	Monthly	23th – February - 2026	

Contents

Document Purpose	2
Document Scope	2
Standards.....	2
Data Backup and Recovery Processes	2
Process Execution – Backup Configuration & Scheduling.....	3
Logging.....	4
Process Execution - Logging	4
Encryption.....	5
Protection of Backup Media.....	5
Process Execution - Protection of Backup Media.....	5
Backup Testing and Restoration.....	6
Process Execution – Restore Testing.....	6
Protection of Online Backups	7
Backup and Data Retention.....	7
Process Execution	7
Physical Media Destruction	8
Process Execution - Physical Media Destruction.....	8
Backup Incident Handling	8
Process Execution – Backup Incident Handling	9
Roles and Responsibilities	10
Update and Review.....	10
Compliance	10

Document Purpose

This standard defines detailed cybersecurity requirements governing backup and recovery of all information assets and IT systems at Saudi EXIM Bank.

It ensures:

- Confidentiality of backup data
- Integrity of backup copies
- Availability and recoverability of critical systems
- Regulatory compliance
- Business continuity readiness

This standard supports the Backup & Recovery Policy and aligns with ISO/IEC 27001:2022 and NIST CSF requirements.

Document Scope

- All Saudi EXIM Bank information systems (on premise and cloud)
- Databases, applications, virtual machines, endpoints, and network configurations
- Third-party hosted systems
- All employees, contractors, and third parties with backup responsibilities

Standards

Data Backup and Recovery Processes

Objective:

Define a structured and controlled backup and recovery process for each IT system.

Risk Implication:

Failure to maintain structured backups may result in permanent data loss, operational disruption, regulatory violations, and financial impact.

Requirements

Backup Process Definition

Each system must have a documented backup procedure including:

- Authorized personnel list
- Backup schedule
- Recovery objectives (RTO/RPO)
- Backup type
- Storage location
- Retention period
- Encryption controls
- Testing procedures
- Logging and monitoring requirements

Business Impact Assessment (BIA)

System owners must conduct a BIA to determine:

- Criticality level
- Maximum tolerable downtime

- Recovery Time Objective (RTO)
- Recovery Point Objective (RPO)

1. Backup Frequency (Minimum Requirements)

System Classification	Backup Type	Frequency
Critical Systems	Full + Incremental	Daily
High	Full Weekly + Incremental Daily	Daily
Medium	Full Weekly	Weekly
Low	Full Monthly	Monthly

Backups must include:

- Operating systems
- Application binaries
- Databases
- Configuration files
- Transaction records
- Audit logs (where required)

2. Backup Media

Approved backup media include:

- Encrypted disk-based storage
- Secure cloud backup solutions
- Secure tape storage (if used)

Personal removable media (USB drives, personal HDDs) are strictly prohibited.

3. Storage Requirements

- One copy onsite
- One encrypted copy offsite
- Logical or physical segmentation between production and backup networks
- Offline or immutable backup for ransomware resilience

Process Execution – Backup Configuration & Scheduling

Trigger:

- New system onboarding
- Infrastructure change
- BIA update
- Annual review

Procedure:

1. System Owner defines RTO/RPO based on approved BIA.
2. System Owner submits Backup Configuration Request in ITSM including:
 - System classification
 - Backup frequency
 - Retention requirement
 - Encryption requirement
3. IT Operations reviews request for completeness.
4. IT configures backup job in approved backup solution including:

- Backup type (Full/Incremental/Differential)
 - Schedule
 - Retention policy
 - Encryption settings
5. IT configures:
 - Onsite storage location
 - Offsite or cloud replication
 - Immutable or offline copy (if applicable)
 6. IT enables backup logging and alerting.
 7. IT performs initial test backup.
 8. IT validates backup job success.
 9. IT updates Backup Configuration Register.
 10. Cybersecurity performs control validation before final approval.

SLA:

Backup must be configured before system go-live.

Evidence Generated:

- ITSM request
- Backup job configuration screenshot/export
- Initial successful backup log
- Backup Configuration Register entry

Logging

Each backup must record:

- Date and time
- System name
- Backup type
- Storage location
- Backup status
- Responsible operator

Failed backups must be rerun within 24 hours.

Process Execution - Logging

Trigger:

- Scheduled backup execution
- Backup failure alert

Procedure:

1. Backup system automatically generates job logs after each execution.
2. IT Operations reviews daily backup dashboard.
3. Failed backups are:
 - Investigated immediately
 - Re-executed within 24 hours
4. Root cause analysis performed if repeated failure occurs.
5. SOC receives critical failure alerts (for critical systems).
6. Weekly summary report generated for:
 - Success rate

- Failures
 - Storage capacity status
7. Monthly report submitted to Cybersecurity.

Evidence Generated:

- Backup job logs
- Failure investigation record
- Weekly summary report

Encryption

- AES-256 encryption for stored backups
- TLS 1.2+ for transmission
- Encryption keys managed under the Cryptographic Key Management Standard

Protection of Backup Media

Objective

Protect backup media from theft, damage, or unauthorized access.

Requirements

- Fire-resistant storage
- Environmental protection
- Access restricted to authorized personnel
- Secure courier for offsite transport
- Annual inventory verification
- Replacement before manufacturer end-of-life

All restoration requests must be logged in a centralized Backup Request Log including:

- Requestor identity
- Business justification
- Approval authority
- Date/time

Process Execution - Protection of Backup Media

Trigger:

- New media deployment
- Offsite transfer
- Annual inventory cycle

Procedure:

1. IT labels all backup media with unique asset ID.
2. Media recorded in Backup Media Inventory Register.
3. Onsite media stored in fire-resistant secure cabinet.
4. Offsite media encrypted before transport.
5. Approved secure courier used for physical transport.
6. Access to storage area restricted via access control system.
7. Annual physical inventory performed by IT.
8. Inventory reconciliation reviewed by Cybersecurity.

Evidence Generated:

- Media inventory log
- Courier transfer receipt
- Annual inventory report

Backup Testing and Restoration

Objective

Ensure backup integrity and restorability.

Requirements

- All backups verified post-execution (hash verification or checksum validation)
- Restoration testing schedule:

System Type	Restore Test Frequency
Critical	Quarterly
High	Semi-Annual
Others	Annual

- Restoration must meet defined RTO
- Test results documented and reviewed by Cybersecurity

Process Execution – Restore Testing

Trigger:

- Scheduled restore test (Quarterly / Semi-Annual / Annual)
- Post-major infrastructure change

Procedure:

1. Cybersecurity initiates scheduled restore test notification.
2. IT selects representative backup set.
3. Restore performed in isolated test environment.
4. Integrity validated via:
 - Checksum verification
 - Data consistency test
5. Restoration time measured against defined RTO.
6. Results documented in Restore Test Report including:
 - Start time
 - End time
 - Issues encountered
 - Success status
7. System Owner confirms data usability.
8. Cybersecurity reviews and signs off.

SLA:

Restore must meet defined RTO.

Evidence Generated:

- Restore Test Report
- RTO measurement record

- Approval sign-off

Protection of Online Backups

- Logical segmentation from production
- Multi-factor authentication for access
- Role-Based Access Control (RBAC)
- Encryption at rest and in transit
- Continuous monitoring for unauthorized access attempts

Backup and Data Retention

Objective

Ensure compliance with legal and regulatory retention requirements.

Requirements

- Retention periods defined per Asset Classification and Data Protection Policy
- Annual retention review
- Semi-annual review for personal data backups
- Secure deletion procedures including:
 - Formal request process
 - Legal approval
 - Secure wipe or cryptographic destruction
 - Key destruction where applicable
 - Logging in Backup Deletion Log

Backup Deletion Log Must Include:

- Request date/time
- Requestor
- Approval authority
- System reference
- Deletion date/time
- Executor name
- Evidence of deletion

Process Execution

Trigger:

- Backup lifecycle expiration
- Legal hold request
- Annual retention review

Procedure:

1. Backup solution automatically flags expired backup sets.
2. IT reviews expiration list against retention policy.
3. If no legal hold exists, IT initiates deletion request in ITSM.
4. Legal or Compliance approval obtained (if required).
5. Secure deletion performed using:
 - Cryptographic erase
 - Secure wipe (if physical media)
6. Deletion logged in Backup Deletion Log.
7. Cybersecurity reviews deletion records quarterly.

Evidence Generated:

- ITSM deletion request
- Deletion log record
- Approval documentation

Physical Media Destruction

Must follow:

- Asset Classification Standard
- Physical Security Standard
- Certified secure destruction methods

Process Execution - Physical Media Destruction

Trigger:

- Media end-of-life
- Media damage
- Retention expiration

Procedure:

1. IT identifies media for destruction.
2. Asset record verified against inventory.
3. Destruction request approved by Cybersecurity.
4. Media transferred to certified destruction vendor.
5. Certificate of destruction obtained.
6. Asset marked as destroyed in inventory register.
7. Destruction certificate archived.

Evidence Generated:

- Destruction request
- Vendor certificate
- Updated inventory record

Backup Incident Handling

Objective

Ensure timely detection, containment, investigation, and recovery from incidents affecting backup integrity, availability, or confidentiality.

Risk Implication

Failure to properly manage backup-related incidents may result in permanent data loss, ransomware propagation, regulatory breaches, business disruption, and reputational damage.

Requirements

1. Backup-related incidents must be managed in alignment with the Incident Response Procedure.

2. A backup incident includes, but is not limited to:
 - Backup failure impacting critical systems
 - Suspected or confirmed ransomware affecting backup repositories
 - Unauthorized access to backup systems
 - Backup data corruption
 - Failed restore during testing or real recovery
 - Loss or theft of backup media
3. All suspected backup integrity issues must be reported immediately to SOC and Cybersecurity.
4. Backup repositories must support isolation capability in case of compromise.
5. Immutable or offline backups must be verified prior to restoration in ransomware scenarios.
6. Forensic investigation must be initiated if malicious activity is suspected.
7. Restoration must only be performed from verified clean backup copies.
8. A post-incident review must be conducted to:
 - Identify root cause
 - Assess control effectiveness
 - Implement corrective actions
9. Regulatory notification must be performed if required under applicable laws.

Process Execution – Backup Incident Handling

Trigger:

- SOC alert
- Backup job failure impacting critical system
- Ransomware detection
- Restore test failure
- Unauthorized access alert
- Manual report by IT or System Owner

Procedure:

1. Incident is logged in the centralized Incident Management System.
2. SOC classifies incident severity based on system criticality and impact.
3. Cybersecurity notifies:
 - IT Operations
 - System Owner
 - CISO (for High/Critical incidents)
4. IT Operations performs immediate containment:
 - Isolate affected backup repository
 - Disable compromised credentials
 - Suspend replication if required
5. Integrity verification performed on:
 - Latest backup copy
 - Immutable/offline backup copy
6. If ransomware suspected:
 - Backup environment disconnected from production
 - Forensic preservation initiated
 - No restoration performed until clean state confirmed
7. Clean backup selected and restoration executed in controlled environment.
8. Restoration time measured against defined RTO.
9. System Owner validates restored data integrity.
10. IT re-enables normal backup operations only after Cybersecurity approval.

- 11. Root Cause Analysis (RCA) completed within 5 business days.
- 12. Post-Incident Report submitted to CISO including:

- Timeline
- Impact assessment
- Recovery outcome
- Control gaps
- Remediation actions

- 13. Corrective actions tracked to closure.

SLA

- Critical backup compromise: Immediate containment (≤ 1 hour)
- Backup failure affecting critical system: Investigated within 4 hours
- Post-incident report: Within 5 business days

Evidence Generated

- Incident ticket record
- SIEM alert log
- Containment action log
- Restore validation report
- Root Cause Analysis document
- Post-incident report
- Remediation tracking record

Roles and Responsibilities

Role	Responsibility
Chief Information Security Officer	Standard Owner
Cybersecurity Department	Review, compliance monitoring
IT Operations	Implementation and execution
System Owners	Define RTO/RPO and backup requirements
Internal Audit	Independent compliance verification

Update and Review

This standard shall be reviewed:

- Annually
- After significant infrastructure change
- After regulatory updates
- After major incident affecting backup integrity

Compliance

- Compliance is mandatory for all Saudi EXIM Bank personnel.
- Violations may result in disciplinary action.
- Cybersecurity Department monitors compliance regularly.
- Audit evidence must be maintained for ISO 27001 certification.

Role	Responsibility
Chief Information Security Officer	Standard Owner
Cybersecurity Department	Review, compliance monitoring
IT Operations	Implementation and execution
System Owners	Define RTO/RPO and backup requirements
Internal Audit	Independent compliance verification